第三章 SQL 注入漏洞与防护
实验分析报告

项目	内容
姓名	古月淼易
学号	2403460104
课程/班级	24 信安 01
实验环境	DVWA、本机浏览器、本地/虚拟机授权靶场（localhost / 127.0.0.1 或内网实验地址）
安全级别	Low、Medium；并补充 SQL Injection Blind 对比

声明：本报告基于本人在 DVWA 本地授权靶场中的实验现象撰写。报告截图均来自本人实验过程，已对 Cookie、Session、账号密码等会话类敏感信息进行脱敏处理，截图中仅保留与实验判断直接相关的本地靶场地址、请求路径和参数。

一、实验授权与边界说明

本次实验仅在教师授权的 DVWA 本地实验环境中完成，访问目标为 localhost / 127.0.0.1 或本地虚拟机/内网实验地址。实验过程中未对任何公网真实网站、第三方系统或未授权目标进行 SQL 注入测试。

本报告只记录本地靶场中的普通输入、异常输入、Medium 控制差异和 Blind 页面行为差异，用于分析“输入 -> 拼接 -> 解析 -> 执行 -> 回显/行为差异 -> 结构分离防护”的因果链。

本报告截图已避免暴露 Cookie、Session、账号密码、完整路径、请求头中的敏感字段等信息。若使用代理工具截图，仅保留与实验判断直接相关的请求参数和返回结果，其他敏感字段应打码。

二、任务 1：数据库与查询条件基础说明

1. 页面输入为什么会与数据库查询有关

网页中的输入框通常不是孤立存在的，它往往对应后端业务功能。例如在 DVWA 的 SQL Injection 页面中，页面要求输入 User ID。这个 ID 会被服务器接收，并作为查询条件进入数据库查询，最终把匹配到的用户信息返回到页面。

最小业务链路可以概括为：输入条件 -> 数据库查询 -> 返回结果。在本次实验中，输入条件是 User ID，数据库查询用于查找对应用户，返回结果表现为页面上的 ID、First name 和 Surname。

2. 用户输入如何进入查询条件

在正常设计中，用户输入应当只是“数据值”。例如输入 1 时，业务含义应当是查询 ID 等于 1 的用户。

但如果后端程序把用户输入直接拼接进 SQL 语句，例如把输入插入到 WHERE user_id = 输入值 这一类条件中，用户输入就可能从“数据值”变成“查询结构的一部分”。数据库并不会自动知道哪些内容来自用户，最终会按照拼接后的整条 SQL 语句进行解析和执行。

3. 为什么这为 SQL 注入创造了可能性

SQL 注入的关键不是某几个字符本身天生危险，而是用户输入被放进了不该进入的 SQL 查询结构。只要输入和查询结构没有分离，输入内容就可能影响原有条件，使数据库执行的语句偏离开发者原本的业务意图。

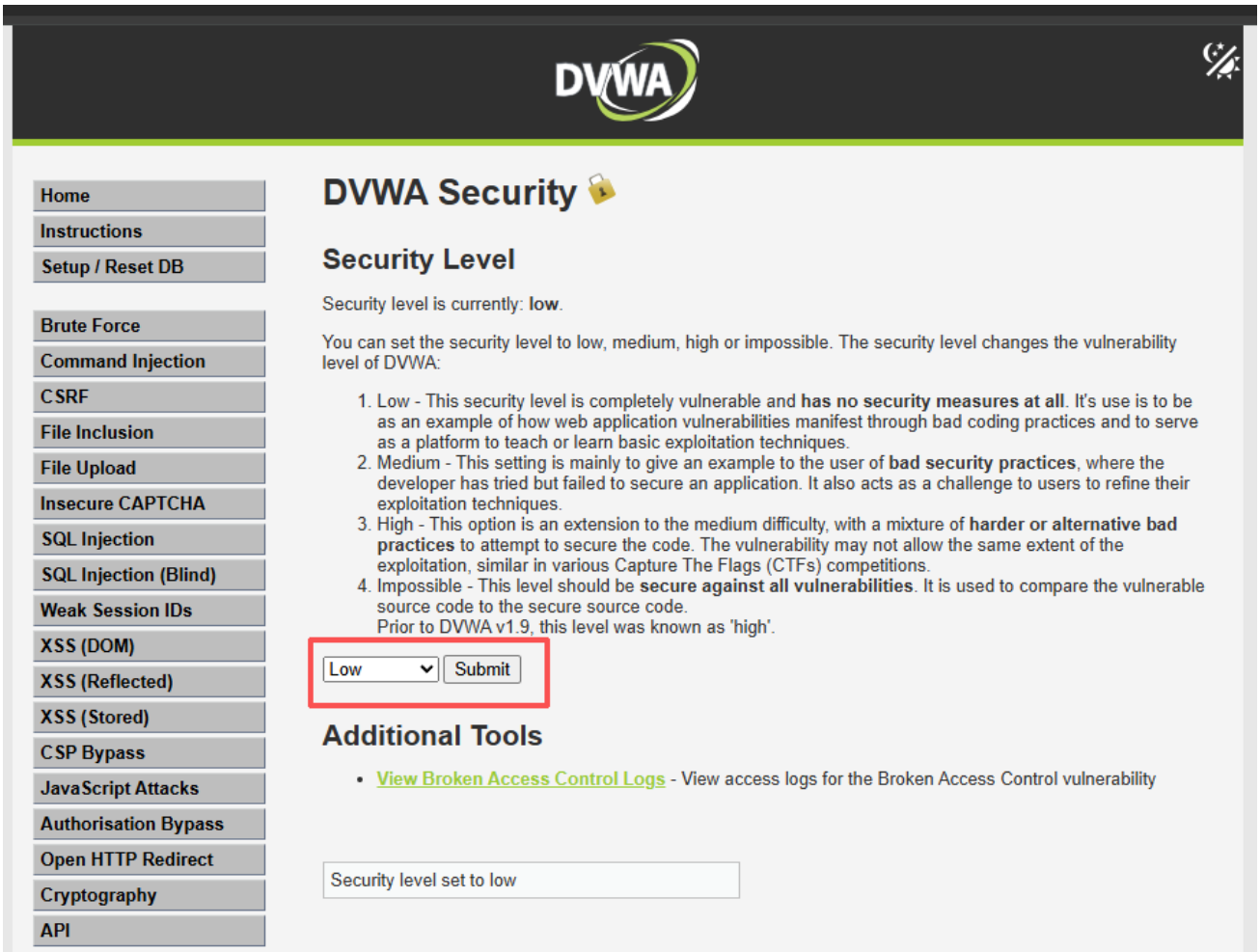
因此，本章的核心主线是：输入 -> 拼接 -> 解析 -> 执行 -> 回显/行为差异 -> 结构分离防护。

三、任务 2：DVWA SQL Injection Low 现象记录

1. 实验页面或实验目标

实验页面：DVWA -> SQL Injection。安全级别：Low。实验目标：在授权本地靶场中对比普通输入与异常输入的返回结果，观察用户输入是否可能影响后端 SQL 查询逻辑。

图 1 DVWA 安全级别设置为 Low

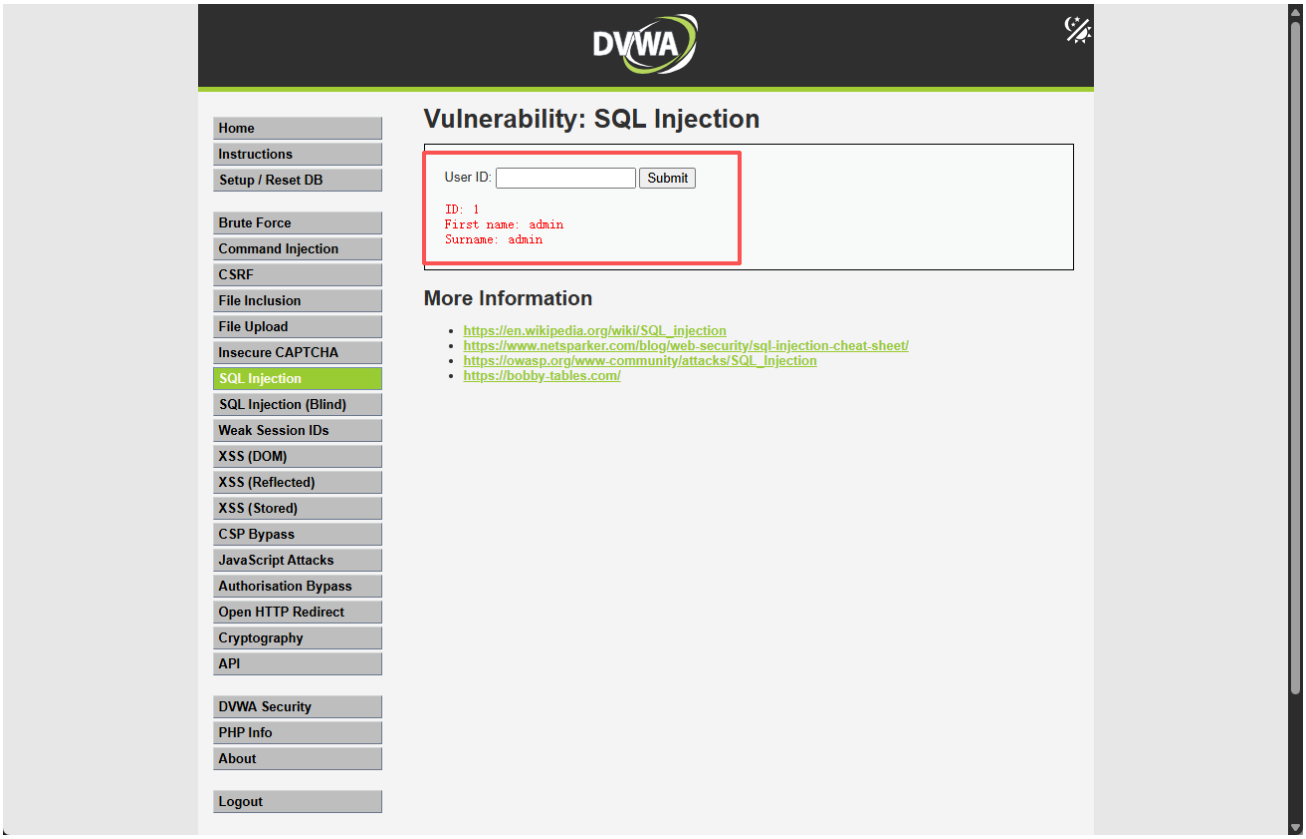


根据图 1，DVWA Security 页面显示当前安全级别为 low，并提示 Security level set to low。该图用于证明后续 SQL Injection 页面观察是在 DVWA Low 级别下完成的。

2. 普通输入与返回结果

普通输入：1。页面返回结果：ID: 1，First name: admin，Surname: admin。

图 2 Low 级别 SQL Injection 页面普通输入 1 的返回结果



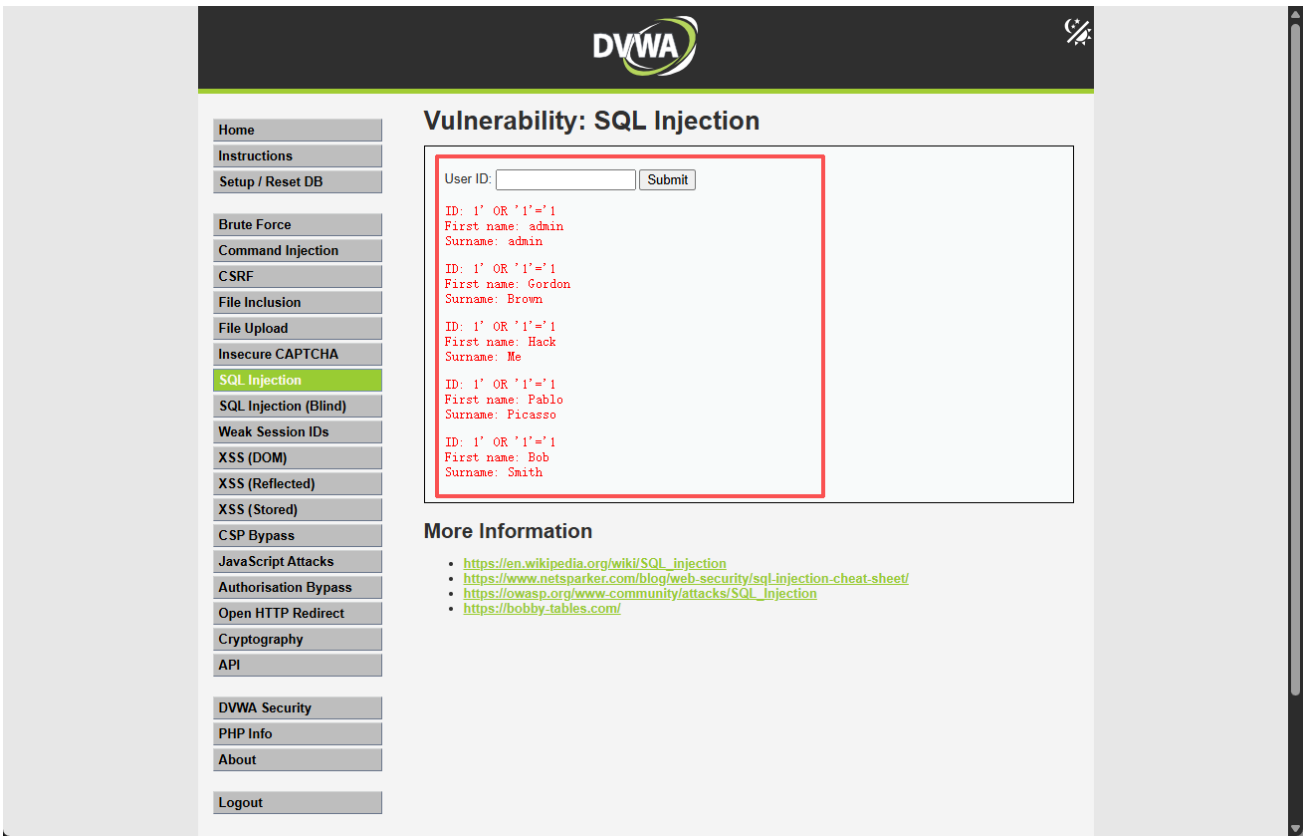
根据图 2，普通输入 1 后页面只返回 ID 为 1 的用户信息，结果范围较小，符合正常业务链路。也就是说，页面输入确实参与了数据库查询，数据库按照输入条件返回对应用户记录。

3. 异常输入与返回结果

异常输入：1' OR '1'='1。该输入仅在 DVWA 本地授权靶场中使用，用于观察查询逻辑是否会被改变。

页面返回结果：页面不再只显示 ID 为 1 的单条记录，而是返回多条用户信息，包括 admin/admin、Gordon/Brown、Hack/Me、Pablo/Picasso、Bob/Smith 等。

图 3 Low 级别 SQL Injection 页面异常输入后的多条返回结果



根据图 3，异常输入后返回结果范围明显扩大。该差异不像普通的“查询条件变化”，因为一个 User ID 查询通常应返回单个匹配用户或无结果，而不是一次性返回多条不同用户记录。

4. 差异支撑的判断

普通输入 1 时，页面返回单条与 ID 对应的用户信息；异常输入后，页面返回多条用户信息。该对比说明，异常输入可能没有被单纯当作普通数据值处理，而是影响了后端 SQL 查询结构，使原本应严格匹配某个 ID 的条件发生了变化。

因此，本实验现象支持以下判断：在 DVWA Low 级别下，用户输入存在进入 SQL 查询结构的可能，查询逻辑被输入污染后，数据库解析和执行结果发生改变。

四、任务 3：机制分析与差异比较

1. 输入如何进入查询结构

本次实验可以用以下链条解释：输入 -> 拼接 -> 解析 -> 执行 -> 回显差异。用户在页面输入 User ID 后，后端把输入用于构造数据库查询。如果程序采用字符串拼接方式构造 SQL，输入内容就可能和原本的 SQL 语法混在一起。数据库执行前会解析完整 SQL 语句，如果用户输入被解析为条件逻辑的一部分，就可能改变原本的查询范围。

图 2 中的普通输入只返回一个用户，说明正常输入表现为单一查询条件；图 3 中的异常输入返回多条用户，说明输入可能改变了查询条件，使查询范围被扩大。

2. 根因是结构被污染，而不是字符本身危险

本题的判断应选择：B. 输入进入了不该进入的查询结构。

理由是：引号、空格、等号等字符在很多正常业务文本中都可能出现，它们并不天然等于漏洞。真正的问题是程序没有把用户输入和 SQL 结构隔离开，使输入被数据库当成 SQL 语法的一部分解析。

如果后端使用参数化查询，用户输入即使包含特殊字符，也会被作为参数值处理，而不是改变 SQL 结构。因此，SQL 注入的根因更准确地说是“查询结构被污染”。

3. Low 与 Medium 的差异

对比项	Low	Medium
输入控制	输入更容易直接进入后端查询构造过程	通常会增加一定输入限制、转义或表单控制，例如页面使用下拉框限制输入自由度
现象表现	更容易观察到明显回显差异，例如异常输入返回多条记录	普通页面交互可能只允许选择固定 ID，但通过请求参数层仍可观察其控制边界
控制思路	基本暴露出拼接式查询的风险	更接近输入层限制或简单处理，主要提高异常输入进入后端的门槛
是否根因解决	否	不一定；只有结构分离才能更可靠解决根因

Low 与 Medium 的差异不应只理解为“某个字符能不能输入”。更重要的是，两者对用户输入进入查询结构的控制程度不同。Medium 可能增加了输入限制或处理，但如果没有使用参数化查询，仍可能只是提高攻击门槛，而不是从根因上分离数据与结构。

补充证据：Medium 级别现象记录

图 4 DVWA 安全级别设置为 Medium

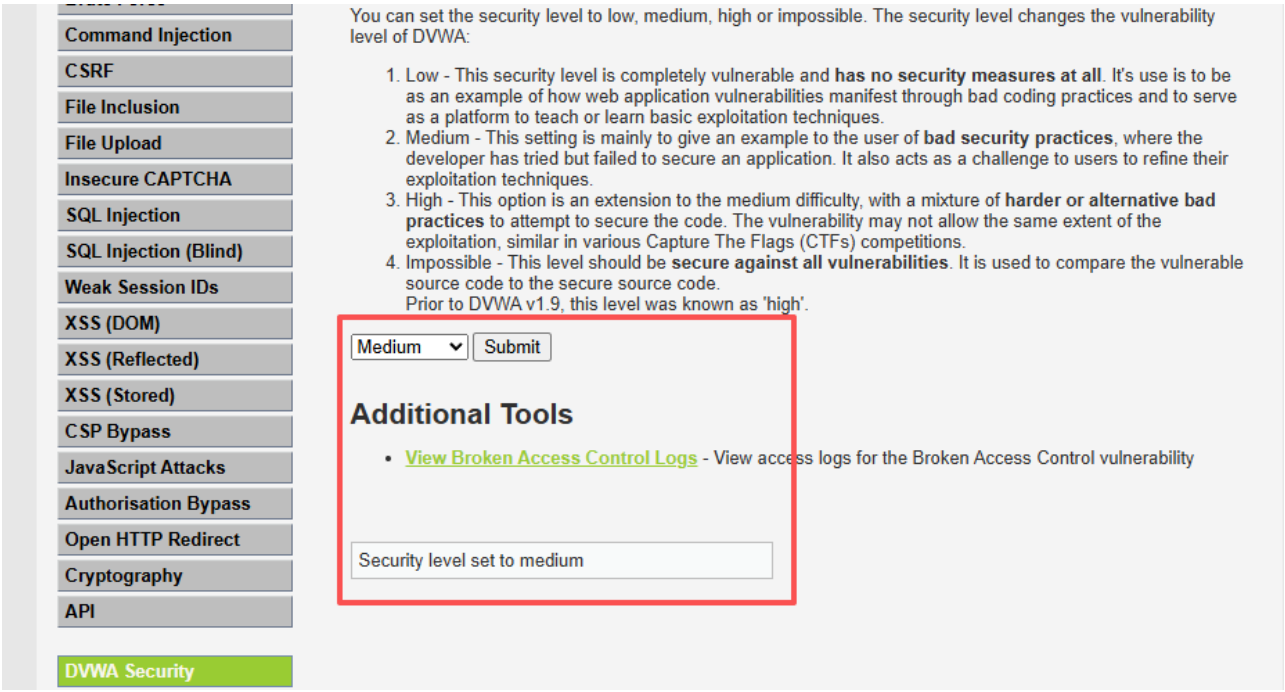


图 4 显示 DVWA Security 页面已将安全级别设置为 Medium。该图用于证明后续 Medium 级别观察是在相应安全级别下完成的。

图 5 Medium 级别下拉选择 ID=1 的正常返回结果

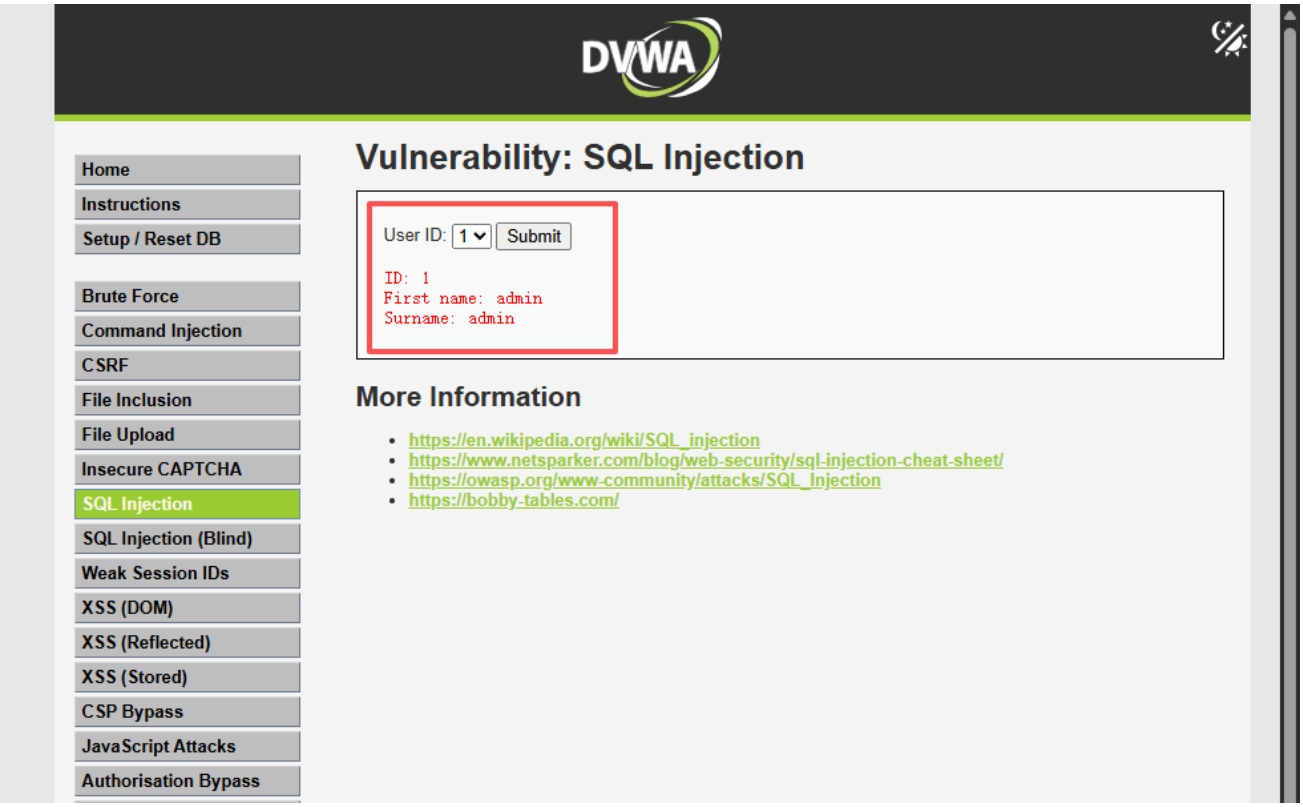


图 5 显示，在 Medium 级别下，页面使用下拉框限制普通用户直接输入内容。选择 ID=1 后返回 admin/admin，说明正常业务查询仍然成立。与 Low 级别的自由输入框相比，Medium 在输入入口上增加了限制。

图 6 Medium 级别下使用本地代理/开发者工具修改请求参数的记录

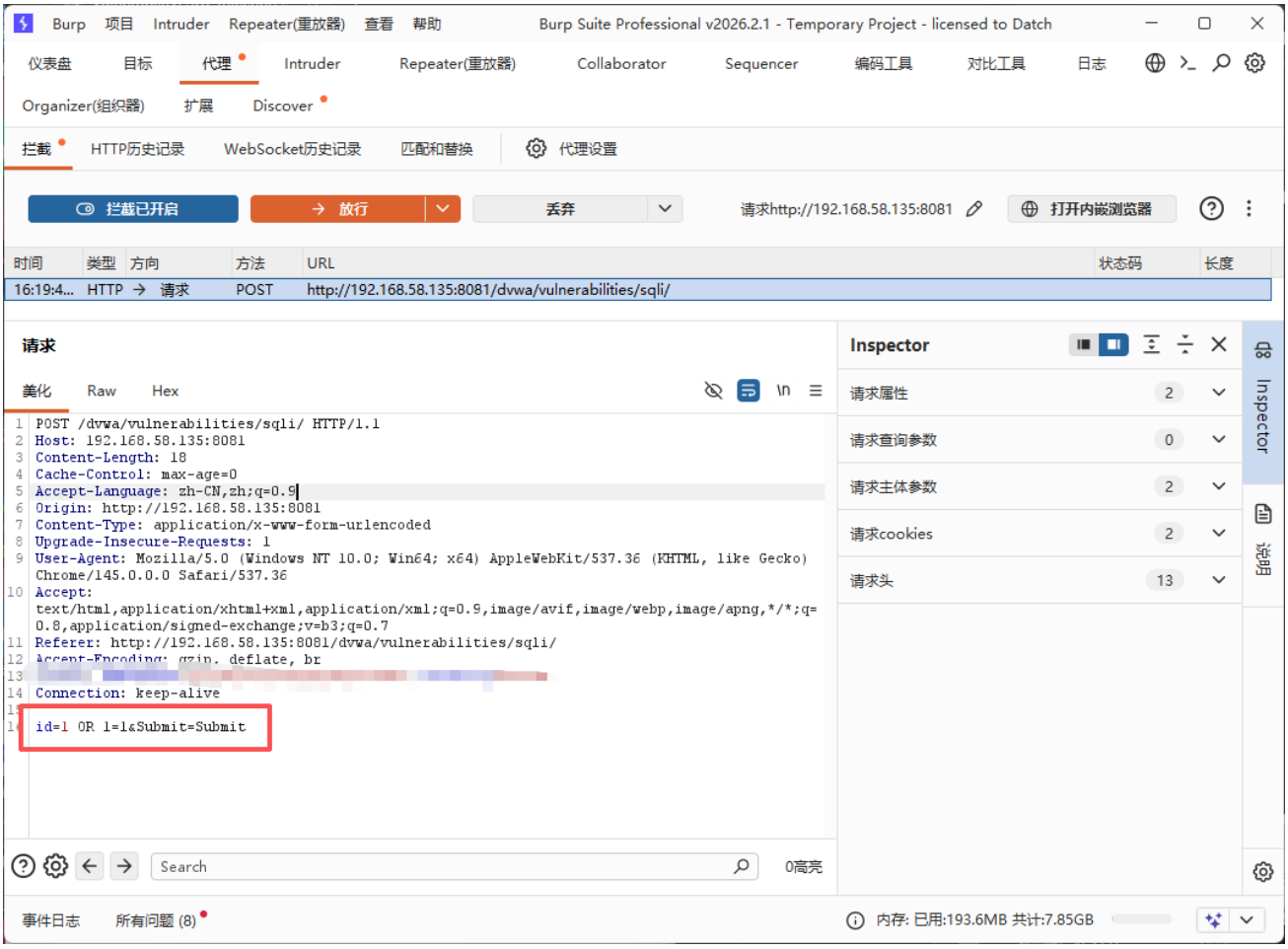


图 6 用于记录 Medium 级别下通过本地代理或开发者工具观察请求参数的过程。该图的作用不是展示攻击公网目标，而是说明在授权靶场中，页面控件限制并不等同于后端结构分离。如果请求参数层仍能被构造，后端仍需要正确处理数据与 SQL 结构的边界。

图 7 Medium 级别修改参数后返回多条用户信息

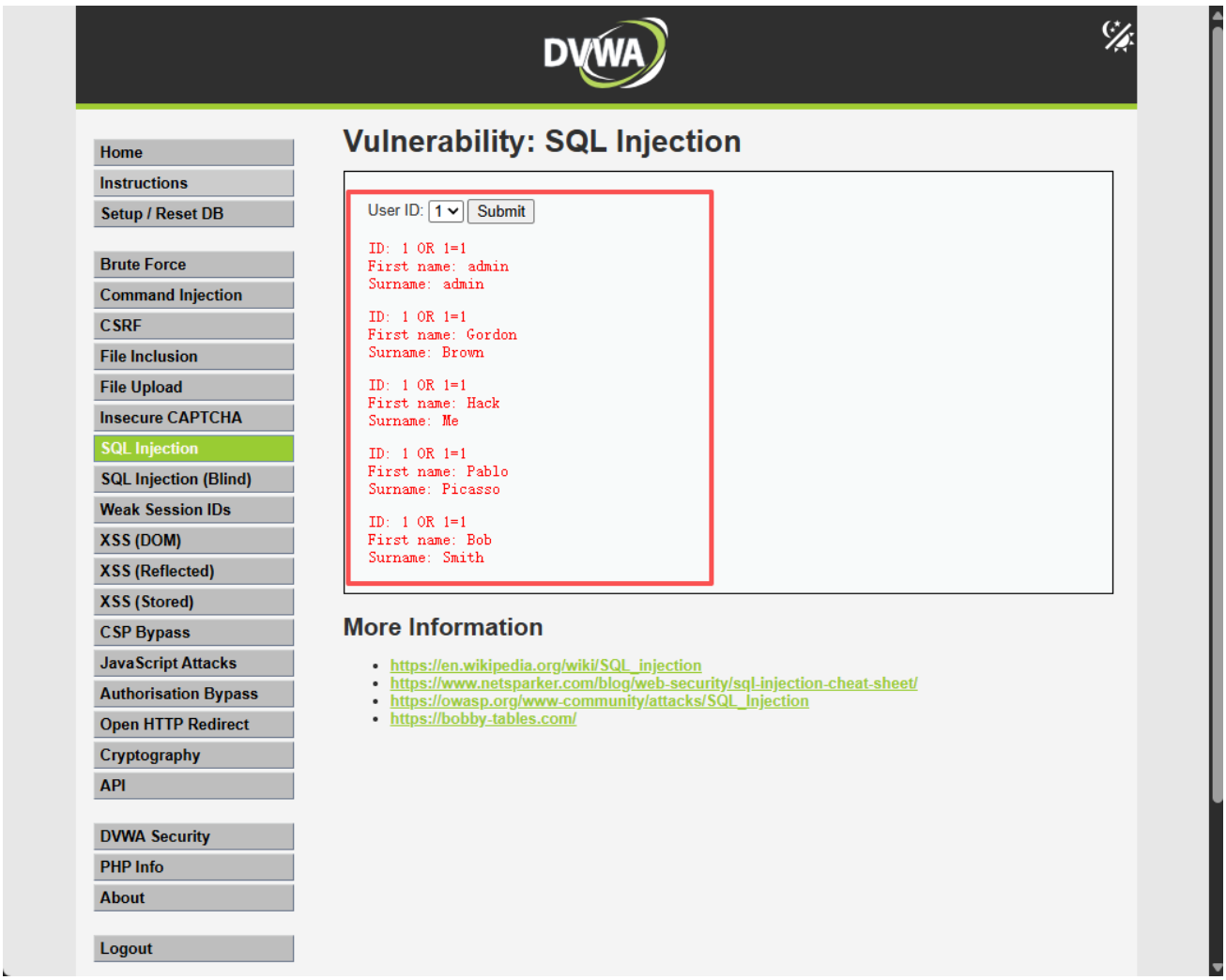


图 7 显示，修改请求参数后页面返回多条用户信息，结果范围明显超出单一 ID 查询的正常范围。该现象说明 Medium 级别的下拉框等页面限制主要属于输入层控制，能够降低异常输入的直接入口，但不能替代参数化查询这种根因控制。

4. 普通 SQL 注入与 Blind SQL Injection 的差异

普通 SQL 注入与盲注的根因相同，都是输入影响了 SQL 查询结构。二者最大的区别应选择：B. 证据形式不同。

普通 SQL 注入通常可以通过页面回显直接看到异常结果，例如图 3 和图 7 中返回多条用户记录。盲注页面可能不直接显示数据库内容，也不显示详细错误信息，只能通过页面是否变化、真假条件差异、响应时间差异等行为证据进行判断。

补充证据：Blind SQL Injection 现象记录

图 8 Blind 页面普通输入 1 的存在提示

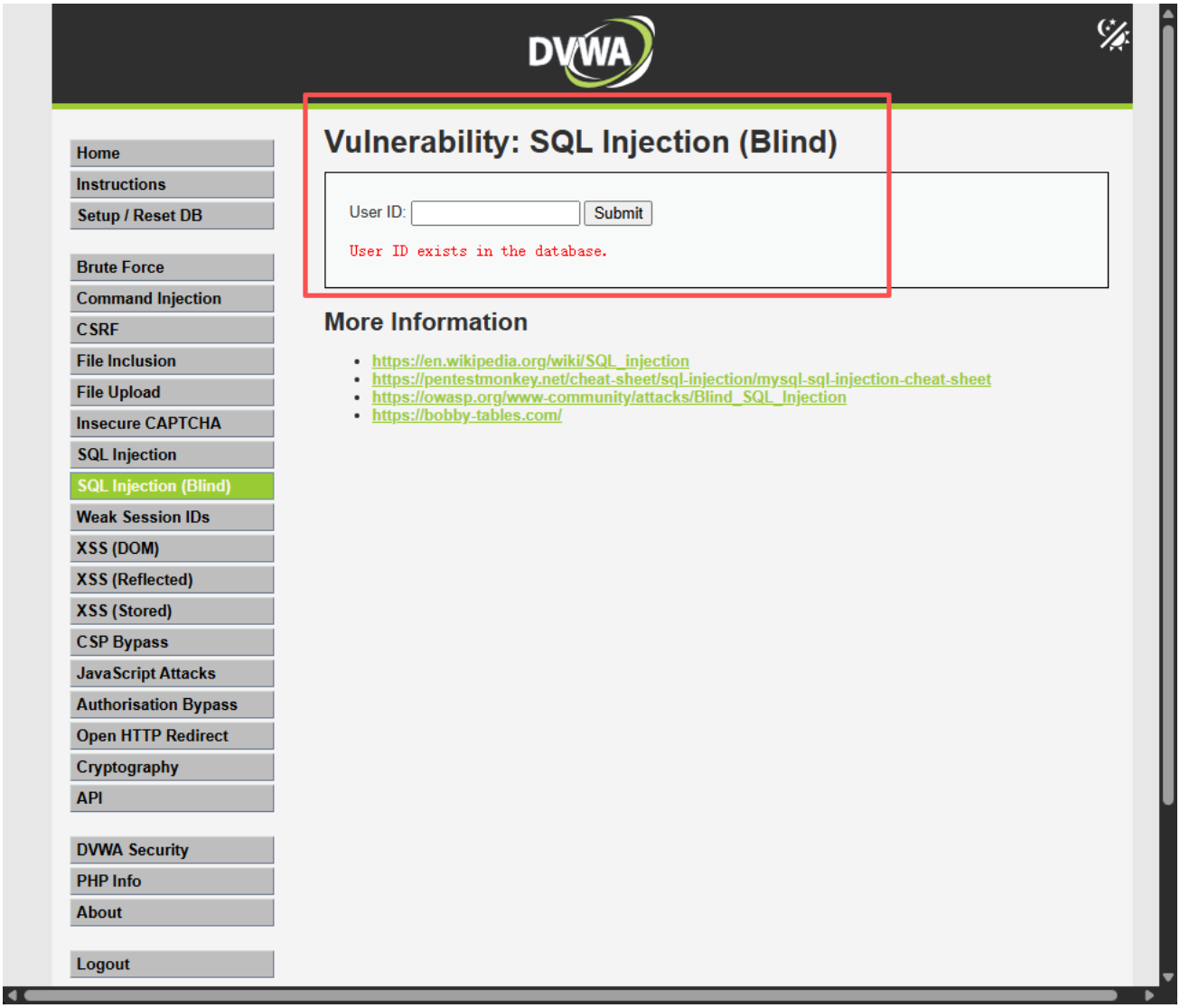


图 8 显示，在 SQL Injection (Blind) 页面提交普通 ID 后，页面只返回“用户存在”类提示，而不直接返回 First name、Surname 等数据库字段。由于页面提交后输入框未保留原输入值，本图主要记录提交后的存在提示。

图 9 Blind 页面条件为真时的存在提示：1' AND '1'='1

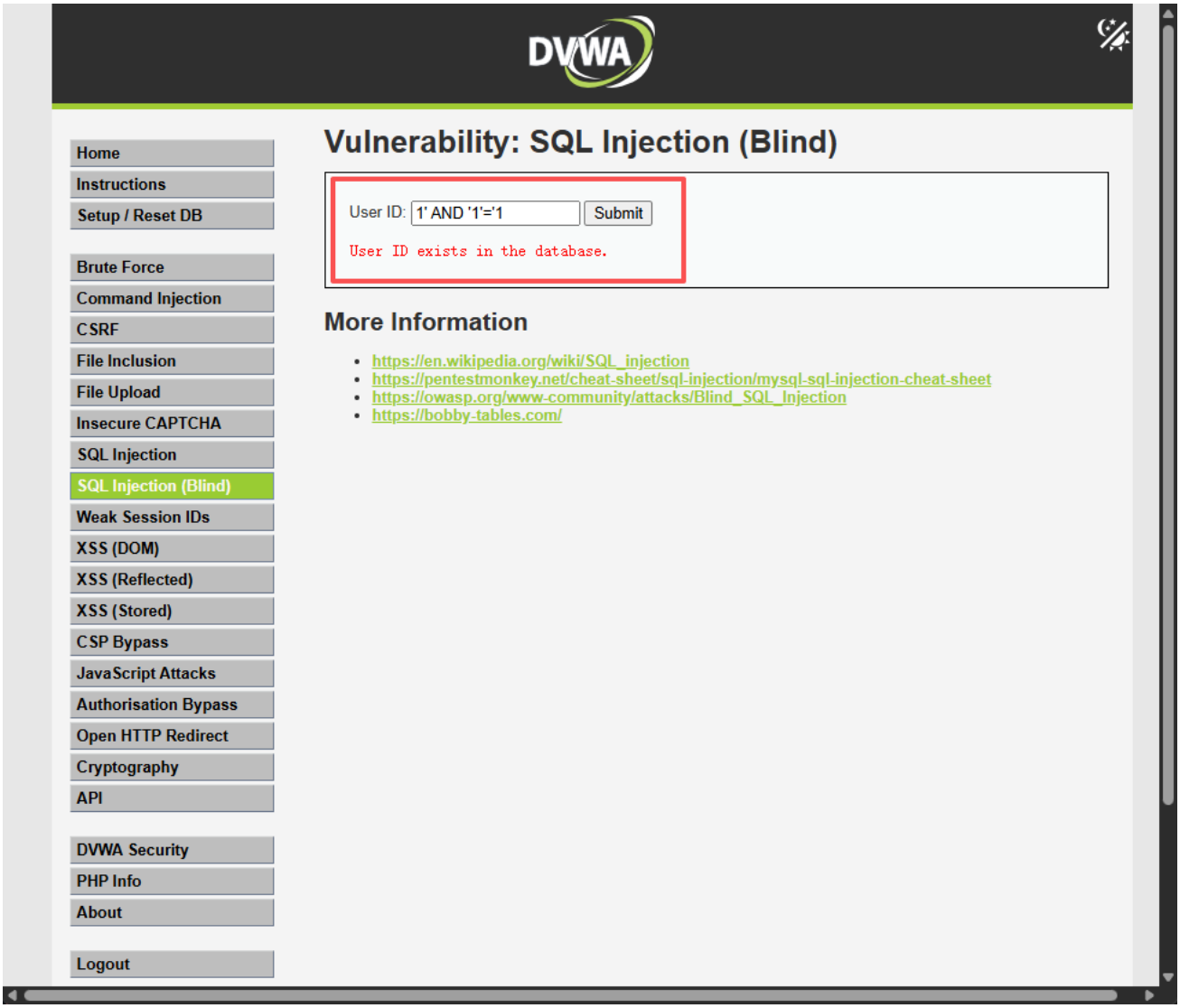


图 9 显示，当异常输入中的判断条件为真时，页面仍返回“User ID exists in the database.”一类提示。虽然页面没有直接显示数据库记录，但提示结果会受到条件真假影响。

图 10 Blind 页面条件为假时的不存在提示：1' AND '1'='2

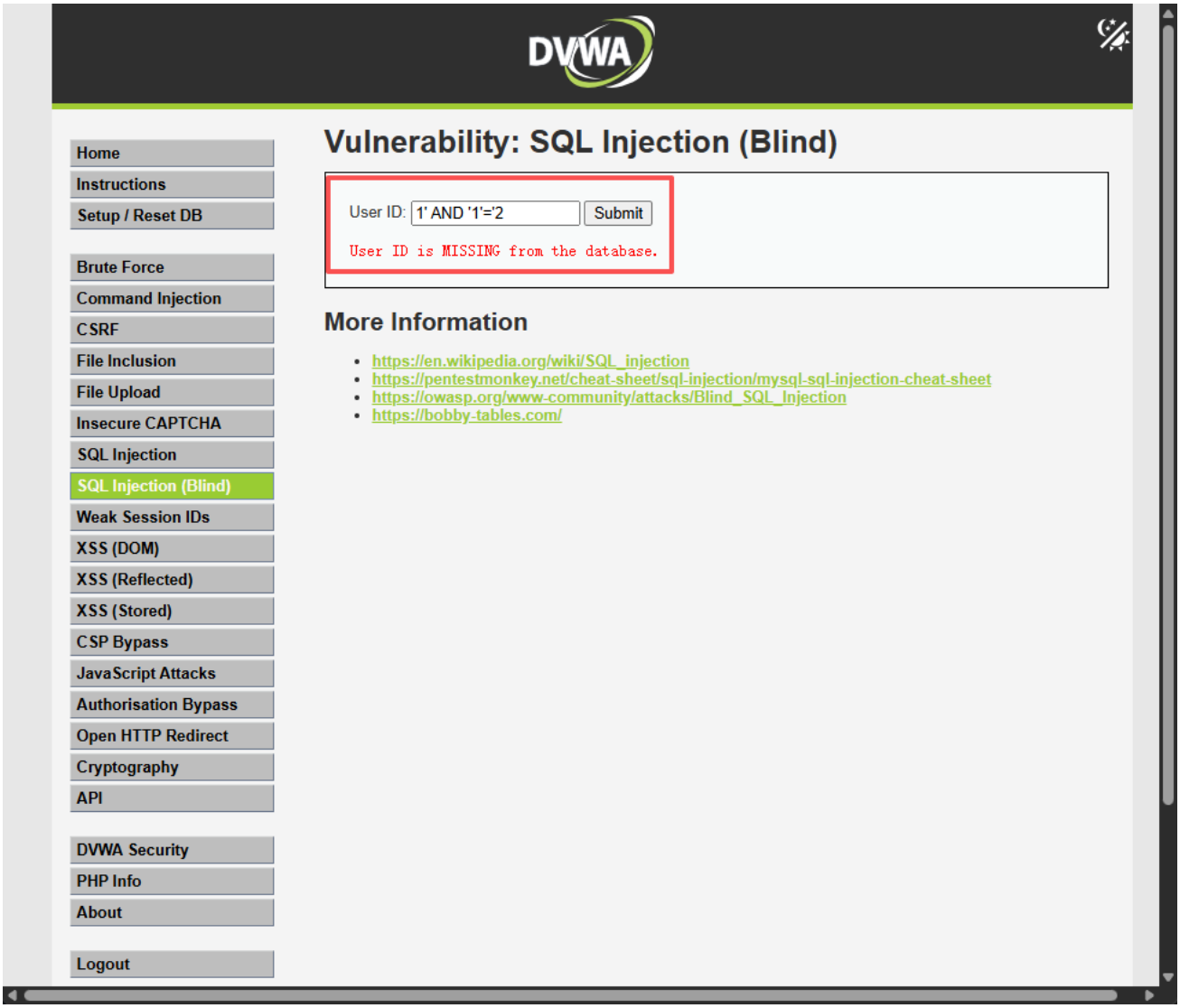


图 10 显示，当异常输入中的判断条件为假时，页面提示变为“User ID is MISSING from the database.”。图 9 与图 10 的对比说明，Blind SQL Injection 与普通 SQL 注入根因相同，都是输入影响了查询结构；不同点在于证据形式从直接数据回显变成了存在/不存在等行为差异。

因此，盲注不是“另一种根因”，而是在相同结构污染根因下，证据从“直接回显”变成了“行为差异”。

5. 强制判断题回答

问题	选择	理由
SQL 注入的根因更接近什么？	B. 输入进入了不该进入的查询结构	特殊字符只是触发现象的表面条件，根因是输入和 SQL 查询结构没有分离。
Blind SQL Injection 和普通 SQL 注入最大差异更接近什么？	B. 证据形式不同	普通注入可能有直接回显；盲注更多依赖页面行为、真假差异或响应时间差异。

五、任务 4：SQL 注入防护清单与解释

防护措施	解决什么问题	控制层	不能替代什么
参数化查询	把 SQL 结构和用户输入数据分离，避免输入被解析成 SQL 语法	根因控制	不能替代最小权限、错误处理和日志监控
输入校验	限制输入格式，例如 ID 字段只允许数字，减少异常输入进入业务流程	暴露面控制	不能替代参数化查询，因为过滤可能被绕过，也可能误伤正常输入
错误处理	避免数据库错误、表名、字段名、路径等信息直接暴露给用户	暴露面控制	不能证明漏洞不存在，也不能修复拼接式查询
最小权限	限制应用数据库账号的操作范围，降低漏洞被利用后的影响	后果范围控制	不能阻止 SQL 注入产生
日志与监控	发现异常请求、重复探测和可疑行为，便于追踪与响应	检测与响应	不能作为主要防护手段，也不能替代结构分离
代码审计	检查是否存在字符串拼接 SQL、错误回显、权限过大等问题	开发过程控制	不能替代运行时权限隔离和持续监控

1. 参数化查询

参数化查询是 SQL 注入防护中最重要的根因控制措施。它让数据库先确定 SQL 结构，再把用户输入作为参数值绑定进去。这样用户输入中的特殊字符不会被解释为 SQL 结构。

但参数化查询不能替代最小权限和错误处理。它主要解决“结构污染”，而权限和错误处理控制的是后果范围与信息暴露。

2. 输入校验

输入校验可以把不符合业务含义的数据挡在前面。例如 User ID 应当是数字，就可以限制为数字类型。这样可以减少异常输入进入后端流程。

但输入校验不能替代参数化查询。因为很多业务字段本来允许复杂字符，如果只依赖过滤特殊字符，既可能被绕过，也可能误伤正常输入。

3. 错误处理

错误处理用于减少信息暴露。数据库错误中可能包含 SQL 片段、表名、字段名、路径等信息。如果直接显示给用户，会帮助攻击者理解系统结构。

正确做法是前端显示通用错误提示，详细错误写入服务器日志供管理员排查。但隐藏错误不等于漏洞消失。

4. 最小权限

最小权限要求应用连接数据库时只拥有完成业务所需的权限。例如只需要查询的业务账号，不应拥有删除表、修改结构或访问无关数据库的权限。

最小权限不能阻止 SQL 注入产生，但可以限制漏洞被利用后的影响范围，属于后果缩减措施。

六、收口项 1：SQL 注入因果链 / 防护关系表

阶段	本次实验中的体现	风险判断	对应防护控制点
输入点	User ID 输入框、Medium 下拉框、Blind 页面输入框接收普通或异常条件	输入可能被后端作为查询条件使用	输入校验、前端提示、服务端类型检查
查询构造	后端根据 User ID 构造数据库查询；Medium 中页面控件限制不等于后端结构分离	如果直接拼接，输入可能进入 SQL 结构	参数化查询、ORM 安全用法、代码审计
数据库解析/执行	数据库按完整 SQL 语句解析并执行	被污染的 SQL 结构可能改变查询逻辑	参数化查询、数据库账号最小权限
结果差异/行为证据	普通注入表现为多条记录回显；Blind 表现为存在/不存在提示差异	结果范围异常扩大或行为提示变化，说明查询逻辑可能被改变	错误处理、最小化回显、日志记录
根因判断	输入不只是数据值，而可能影响查询结构	根因是查询结构被污染	结构分离：参数化查询
后果范围	返回不属于单一 ID 查询范围的多条用户信息；盲注可通过行为差异推断条件真假	可能造成越权读取、数据泄露或进一步攻击	最小权限、分级授权、监控告警

从关系表可以看出，本次实验的证据链不是单纯“输入了异常字符”，而是普通输入与异常输入在返回结果或行为提示上出现了不符合正常业务逻辑的差异。该差异指向查询结构可能被用户输入污染。防护上应优先使用参数化查询控制根因，再使用输入校验、错误处理、最小权限和日志监控控制暴露面与后果范围。

下一步如果继续验证，应进一步比较 Medium 源码或后端处理方式，并在 Blind 页面补充更多真假条件或响应差异记录。但无论普通注入还是盲注，最终防护方向都应回到结构分离，而不是只记忆某个 payload。

七、收口项 2：学生自评表

自评问题	我的回答
我本章最清楚的一点是什么？	我最清楚的一点是：SQL 注入的根因不是某个字符本身危险，而是用户输入进入了 SQL 查询结构，导致原本的查询逻辑被改变。通过 Low 和 Medium 的对比，我也进一步理解到页面输入限制不等于根因防护。
我最容易混淆的一点是什么？	我最容易混淆的是普通 SQL 注入和盲注的区别。通过补充 Blind 页面截图，我理解到二者根因相同，区别主要是证据形式不同：普通注入可能直接回显数据，盲注更多依赖存在/不存在提示或其他行为差异。
我本次作业中哪一段最需要教师复核？	我认为最需要教师复核的是 Low 与 Medium 差异分析，以及 Medium 中通过请求参数层观察控制边界的说明。我希望确认自己对输入层限制与结构分离防护的区分是否准确。
如果重做一次，我会优先改哪一部分？	如果重做一次，我会优先改进证据记录部分。除了截图，我会更系统地记录输入、返回结果、页面提示差异，以及每个差异支撑的判断。

八、收口项 3：AI 输出审核与人工复核记录

1. 本作业哪些内容使用过 AI 辅助

本报告的结构整理、部分语言表达、机制分析框架、防护清单分类、关系表排版，以及 Medium / Blind 补充证据的文字组织使用过 AI 辅助。实验截图、实验环境和页面现象来自本人在 DVWA 本地授权环境中的实际操作。

2. 哪些判断是我自己复核后保留的

- 图 1 显示 DVWA 安全级别为 Low，证明 Low 级别实验与报告描述一致。
- 图 2 显示普通输入 1 只返回 admin/admin 一条用户信息，符合正常 ID 查询。
- 图 3 显示异常输入后返回多条用户信息，说明查询结果范围异常扩大。
- 图 4 至图 7 显示 Medium 级别增加了输入限制，但页面限制不能简单等同于结构分离。
- 图 8 至图 10 显示 Blind 页面不直接回显用户数据，而是通过存在/不存在提示差异体现条件真假。
- SQL 注入的根因应归纳为查询结构被污染，而不是特殊字符本身危险。
- 普通 SQL 注入和盲注的根因相同，但证据形式不同。
- 参数化查询属于根因控制，错误处理和最小权限分别偏向暴露面控制与后果范围控制。

3. 哪些 AI 输出不准确并进行了修正

AI 输出中容易把所有防护措施都写成同一层控制。本人根据作业要求进行了修正：参数化查询对应根因控制；输入校验主要减少暴露面；错误处理减少信息泄露；最小权限限制漏洞被利用后的后果范围。

在复核 AI 辅助内容时，我重点检查了是否存在“过滤特殊字符即可完全防止 SQL 注入”这类绝对化表述，并将相关内容修正为“输入校验不能替代参数化查询”。同时，我将 Medium 和 Blind 的截图证据与文字结论逐一对应，避免把没有截图支撑的推断写成直接实验结论。

4. 我最终如何确认结论和证据一一对应

证据	支持的结论
图 1：DVWA Security 页面显示 Low	Low 级别实验在授权靶场边界内完成。
图 2：Low 普通输入 1 返回 ID 1、admin/admin	页面输入会进入数据库查询，并按正常条件返回对应结果。
图 3：Low 异常输入后返回多条用户信息	异常输入可能改变查询逻辑，导致结果范围扩大。
图 4、图 5：Medium 设置与正常下拉选择结果	Medium 相比 Low 增加了输入入口限制。
图 6、图 7：Medium 请求参数修改记录与多条返回结果	页面控件限制不能替代后端结构分离，防护仍应回到参数化查询。
图 8：Blind 普通输入返回存在提示	Blind 页面不直接回显用户数据。
图 9、图 10：Blind 条件真假导致提示差异	盲注证据表现为行为/提示差异，而不是直接数据回显。
防护清单分层	不同防护措施分别控制根因、暴露面或后果范围，不能互相替代。

九、提交前自查清单

自查项	状态
只在 DVWA / localhost / 本地虚拟机 / 教师授权环境中实验	已确认
截图中 Cookie、Session、账号密码、无关请求头等敏感信息已脱敏	已确认
说明了普通查询变化与查询逻辑被改变的区别	已确认
明确写出根因是查询结构被污染	已确认
区分了普通 SQL 注入与盲注的证据差异	已确认
补充了 Medium 控制思路的实际截图和说明	已完成
防护措施区分根因控制、暴露面控制、后果范围控制	已确认
完成了关系图/关系表	已确认
完成了学生自评表	已确认
完成了 AI 输出审核与人工复核记录	已确认